Eco-Inversión CR – Flujos críticos

Owner: Diana
Reviewer:
Contributors:
Date Generated: Mon Nov 09 2026

Executive Summary

High level system description

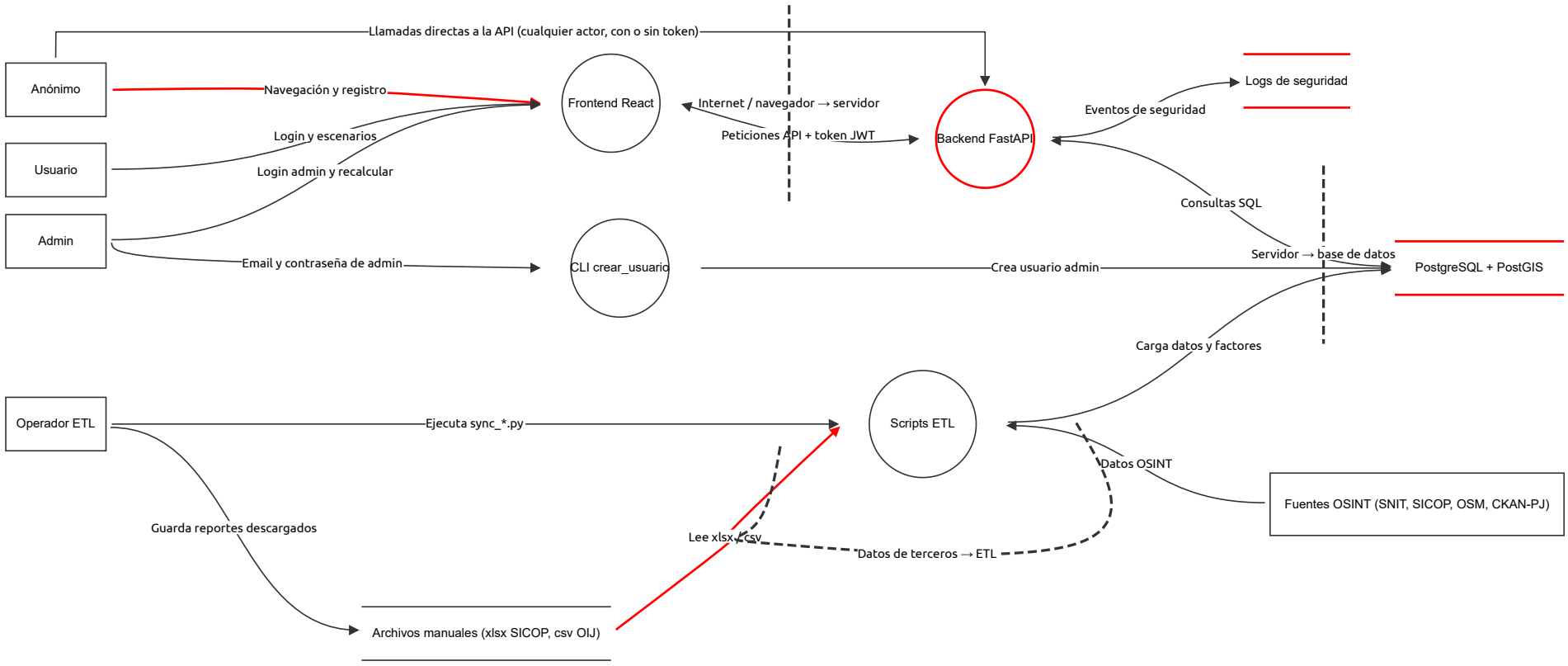
Modelo de amenazas STRIDE de los flujos F1 (autenticación), F2 (recalcular índice) y F3 (escenarios privados) definidos en docs/autenticacion.md.

Summary

Total Threats	11
Total Mitigated	2
Total Open	9
Open / Critical Severity	0
Open / High Severity	1
Open / Medium Severity	7
Open / Low Severity	1

Flujos F1–F3

DFD de los flujos críticos: actores, backend, base de datos, ETL y fuentes OSINT externas, con sus fronteras de confianza.



Flujos F1–F3

Anónimo (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Usuario (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Admin (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Operador ETL (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Frontend React (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Backend FastAPI (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T-03 Token JWT falsificado si se filtra la clave secreta	Spoofing	Medium	Open	6 (P2 × I3)	Recurso: proceso Backend FastAPI, que valida los tokens JWT con una clave secreta guardada en variables de entorno. Si esa clave se filtra (repositorio, .env compartido, logs), cualquiera puede firmar un token que el backend acepta como válido. Impacto: el atacante pone en el token el id de cualquier usuario, incluso el de un admin. El rol no va dentro del token (se vuelve a leer de la base en cada petición), pero el backend cree que la sesión es de esa persona, así que puede recalcular el índice o ver escenarios privados. También es una elevación de privilegios (E). Prioridad: Probabilidad 2 (primero tiene que filtrarse la clave) × Impacto 3 (control total como admin) = 6 → Media.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	T-04 Credential stuffing contra el login	Spoofing	Medium	Open	6 (P3 × I2)	Recurso: proceso Backend FastAPI, endpoint POST /auth/login. El bloqueo después de varios intentos fallidos es por cuenta, pero no hay límite de intentos por IP. Impacto: un atacante prueba listas de correos y contraseñas filtradas de otros sitios (probando pocas veces cada cuenta para no activar el bloqueo) y entra a las cuentas de usuarios que reutilizan contraseñas; puede ver o borrar sus escenarios privados. Prioridad: Probabilidad 3 (ataque automatizado, barato y muy común) × Impacto 2 (afecta cuentas de usuario normales, no de admin, que se crea solo por CLI) = 6 → Media.	
5	T-06 Saturación del backend por falta de límite de peticiones	Denial of service	Medium	Open	4 (P2 × I2)	Recurso: proceso Backend FastAPI. No hay un límite global de peticiones por IP, y los endpoints que devuelven GeoJSON de mapas son pesados para el servidor y la base de datos. Impacto: muchas peticiones seguidas a esos endpoints pueden dejar lenta o caída la aplicación para todos los usuarios. Prioridad: Probabilidad 2 (fácil de hacer, pero el proyecto no es un objetivo muy atractivo) × Impacto 2 (caída temporal, sin pérdida de datos) = 4 → Media.	
6	T-05 Bloqueo deliberado de cuentas ajenas	Denial of service	Medium	Open	6 (P3 × I2)	Recurso: proceso Backend FastAPI, endpoint POST /auth/login. Después de varios intentos fallidos la cuenta se bloquea temporalmente, sin importar desde dónde vienen los intentos. Impacto: un atacante que conoce el correo de una víctima falla el login a propósito y deja a esa persona sin acceso a sus escenarios; repetido sobre muchas cuentas, deja la aplicación inservible para los usuarios. Prioridad: Probabilidad 3 (solo necesita el correo de la víctima y un script) × Impacto 2 (pérdida de acceso temporal, sin pérdida de datos) = 6 → Media.	
8	T-08 Token robado sigue válido porque no se puede revocar	Spoofing	Medium	Open	4 (P2 × I2)	Recurso: proceso Backend FastAPI. Los JWT no se guardan en el servidor, así que no hay forma de invalidarlos antes de que expiren a los 30 minutos: no existe un cierre de sesión del lado del servidor. Desactivar la cuenta sí corta el token de inmediato, porque el backend revisa el campo activo en cada petición. Impacto: si alguien roba un token (por ejemplo desde el navegador o un equipo compartido), puede usarlo y hacerse pasar por el usuario hasta que el token expire. Además, la aplicación no tiene opción para cambiar la contraseña. Prioridad: Probabilidad 2 (primero hay que robar el token) × Impacto 2 (acceso limitado al tiempo de vida del token) = 4 → Media.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	T-11 Usuario normal intenta hacer acciones de admin	Elevation of privilege	Low	Mitigated	3 (P1 × I3)	Recurso: proceso Backend FastAPI, flujo F2 "Login admin y recalcular" (POST /indice-viabilidad/recalcular) y el registro (POST /auth/registro). Un usuario normal intenta hacer algo que solo puede hacer el admin: llamar a recalcular el índice, o registrarse mandando "rol": "admin". Impacto: si lo lograra, podría cambiar el índice oficial que ven los inversionistas (integridad del flujo F2). Prioridad: Probabilidad 1 (ya está controlado y probado) × Impacto 3 (afecta el resultado principal del sistema) = 3 → Baja.	requiere_admin (backend/app/auth.py) relee el rol de la base en cada petición y responde 403 si no es admin. El registro usa extra="forbid": si viene el campo "rol" responde 422 y no crea la cuenta. El admin solo se crea por la línea de comandos (python -m app.crear_usuario). Probado en tests/api/test_autorizacion.py (test_recalcular_como_usuario_403_y_el_indice_no_cambia, test_rol_degradado_pierde_el_permiso_con_token_vigente) y tests/api/test_auth.py (test_registro_no_permite_elegir_rol_admin).

CLI crear_usuario (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Scripts ETL (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

PostgreSQL + PostGIS (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T-01 Base de datos expuesta con contraseña por defecto	Information disclosure	High	Open	9 (P3 × I3)	Recurso: PostgreSQL + PostGIS. En docker-compose.yml el puerto 5432 está publicado y POSTGRES_PASSWORD tiene "changeme" por defecto. Impacto: un atacante podría leer o cambiar usuarios (hashes de contraseñas), escenarios privados y el índice de viabilidad. Prioridad: Probabilidad 3 (puerto abierto + contraseña conocida, fácil de encontrar con un escaneo) × Impacto 3 (toda la base de datos) = 9 → Alta.	

Navegación y registro (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T-10 Enumeración de cuentas en el registro	Information disclosure	Low	Open	3 (P3 × I1)	Recurso: flujo "Navegación y registro", endpoint POST /auth/registro. Si el correo ya existe, la API responde 409 (conflicto), distinto a cuando el registro funciona. Impacto: un atacante puede averiguar qué correos tienen cuenta y usar esa lista para credential stuffing (T-04) o para bloquear cuentas (T-05). Prioridad: Probabilidad 3 (basta con probar correos en el formulario) × Impacto 1 (solo revela que la cuenta existe, no datos) = 3 → Baja.	

Peticiones API + token JWT (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T-09 Acceso a escenarios de otro usuario (IDOR)	Information disclosure	Low	Mitigated	3 (P1 × I3)	Recurso: flujo "Peticiones API + token JWT", rutas /escenarios/{id} (ver, editar, borrar y exportar CSV). Un usuario autenticado podría cambiar el id en la URL para intentar acceder a escenarios de otra persona (IDOR). Impacto: lectura o modificación de escenarios privados de otros usuarios. Prioridad: Probabilidad 1 (el backend ya verifica que el escenario pertenezca al usuario del token; el riesgo queda si un endpoint nuevo olvida esa verificación) × Impacto 3 (datos privados de terceros) = 3 → Baja.	_obtener_propio (backend/app/routers/escenarios.py) compara el dueño del escenario con el usuario del token y responde 404 si no coincide, igual que si no existiera, y registra el evento acceso_denegado. Los UPDATE y DELETE repiten usuario_id en el WHERE. Probado en tests/api/test_autorizacion.py (test_escenario_de_otro_404_sin_exponer_datos y test_modificar_escenario_de_otro_404_y_no_cambia), también con el rol admin.

Logs de seguridad (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T-07 Logs sin integridad ni retención	Repudiation	Medium	Open	4 (P2 × I2)	Recurso: almacén Logs de seguridad. Los eventos de seguridad (logins, bloqueos, recálculo del índice) se escriben en la salida estándar (stdout) del contenedor, sin protección de integridad ni política de retención. Impacto: quien tenga acceso al servidor puede borrar o alterar los registros, y al reiniciar o recrear el contenedor se pueden perder; después no se puede demostrar quién hizo una acción (por ejemplo, quién recalculó el índice). Prioridad: Probabilidad 2 (requiere acceso al servidor o que se recree el contenedor) × Impacto 2 (se pierde la trazabilidad, no los datos del negocio) = 4 → Media.	

Archivos manuales (xlsx SICOP, csv OIJ) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Fuentes OSINT (SNIT, SICOP, OSM, CKAN-PJ) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Login y escenarios (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Login admin y recalcular (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Llamadas directas a la API (cualquier actor, con o sin token) (Data Flow)

Description: Anónimo, Usuario y Admin pueden llamar a la API sin pasar por el frontend (curl, Swagger, scripts). Se dibuja una sola flecha desde Anónimo para no saturar el diagrama.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Consultas SQL (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Eventos de seguridad (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Email y contraseña de admin (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Crea usuario admin (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Ejecuta sync_*.py (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Guarda reportes descargados (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Lee xlsx / csv (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T-02 Datos manipulados en la entrada del ETL	Tampering	Medium	Open	6 (P2 × I3)	Recurso: flujo "Lee xlsx / csv" (archivos SICOP y OIJ descargados a mano) y también "Datos OSINT". Los scripts ETL cargan a la base de datos lo que leen, sin verificar la integridad del archivo (hash o firma) ni su origen. Impacto: datos falsos o alterados cambian los factores y el índice de viabilidad, y los usuarios tomarían decisiones de inversión con información incorrecta. Prioridad: Probabilidad 2 (requiere alterar un archivo descargado o una fuente externa; no es trivial, pero nada lo detecta) × Impacto 3 (afecta el resultado principal del sistema) = 6 → Media.	

Datos OSINT (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Carga datos y factores (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations